Email Forensic Analysis Report

Case EFT-20261028-16262A89 - generated 2026-10-28T06:55:57+00:00

Case identifier	EFT-20261028-16262A89
Analysis time (UTC)	2026-10-28T06:55:57.718008+00:00
Report generated (UTC)	2026-10-28T06:55:57+00:00
Tool	Email Forensics Toolkit v1.0.0
Source	S04_bec_freemail_replyto.eml
Input method	file upload
Evidence size	916 bytes
SHA-256 (at intake)	17f9188626750e5946e1a88a4b8d9fe042c3649481f7238f01376b9b2102d9bf
Integrity re-check	INTACT - stored original matches the intake hash (verified 2026-10-28T06:55:57+00:00)
Analysis settings	scoring=severity_sum; trusted domains=['uni-example.edu']; trusted authserv-ids=auto; extra protected domains=none; DNS lookups=off; clock-skew tolerance=5 min

1. Risk assessment

Category: **HIGH** Score: **11** Approach: severity_sum (thresholds medium ≥ 3, high ≥ 6)

The score ranks how many and how serious the header indicators are. It is not a calibrated probability of maliciousness, and a low score does not prove a message is safe (e.g. a compromised legitimate account passes every header check).

Rule	Finding	Severity	Points	Why these points
AUTH-DMARC-FAIL	DMARC failed for the visible From domain	high	6	high severity = 6 point(s)
SENDER-REPLYTO-MISMATCH	Reply-To points to a different organisation	medium	3	medium severity = 3 point(s)
AUTH-SPF-FAIL	SPF softfail for the envelope sender	low	1	low severity = 1 point(s)
SENDER-RETURNPATH-MISMATCH	Envelope sender (Return-Path) belongs to a different organisation	low	1	low severity = 1 point(s)

2. Extracted header information

From	"Partner Corp Accounts" <accounts@partner-corp.com>
Sender	-
Reply-To	<partnercorp.payments@gmail.com>
Return-Path	<bounce@cheap-smtp.biz>
To	<student@uni-example.edu>
Cc	-
Subject	Updated bank details for invoice 4471
Date	Mon, 14 Sep 2026 09:29:00 +0000 (parsed: 2026-09-14T09:29:00+00:00)
Message-ID	<379185413825.964297@partner-corp.com>
Domains observed	partner-corp.com, gmail.com, cheap-smtp.biz
IP addresses	10.20.0.11 (private), 91.215.85.12 (public)
Header fields	12 total; 2 Received; full message

3. Apparent delivery route (earliest first)

Trusted infrastructure: uni-example.edu. Origin IP seen by trusted server: 91.215.85.12 (public). Hops marked 'claimed' were written by servers outside the trust boundary and may be forged.

#	From (HELO / rDNS / IP)	By	Timestamp	Delay	Trust
1	mail.cheap-smtp.biz / mail.cheap-smtp.biz / 91.215.85.12	mx1.uni-example.edu	2026-09-14T09:30:00+00:00	-	trusted
2	mx1.uni-example.edu / mx1.uni-example.edu / 10.20.0.11	mailbox01.uni-example.edu	2026-09-14T09:30:12+00:00	+12 s	trusted

4. Authentication results

Mechanism	Status	Reported	Domain	Interpretation
SPF	fail	softfail	cheap-smtp.biz	The domain's SPF record marks the IP as probably unauthorised (~all).

Mechanism	Status	Reported	Domain	Interpretation
DKIM	**neutral**	none	-	No record/signature exists ('none'): The message was not signed, or the signature could not be evaluated.
DMARC	**fail**	fail	partner-corp.com	Neither SPF nor DKIM produced a pass aligned with the visible From domain. This is the strongest header-level sign of From spoofing.

Alignment (computed): From=partner-corp.com, SPF domain=cheap-smtp.biz (aligned: False), DKIM pass domains=none (aligned: False). Relaxed alignment computed by this tool from the trusted results; it approximates, but is not, a DMARC evaluation.

Trusted authserv-ids: mx1.uni-example.edu; untrusted results ignored: 0.

5. Findings

1. DMARC failed for the visible From domain [HIGH] AUTH-DMARC-FAIL

Evidence: dmarc=fail header.from=partner-corp.com

Evidence: published policy p=NONE

Why it matters: DMARC ties the From address the recipient sees to a domain that passed SPF or DKIM. A failure means the From domain did not authorise this message.

Limitations: Mailing lists and forwarders can cause DMARC failures for genuine mail; the result is only as reliable as the receiving server that recorded it.

2. Reply-To points to a different organisation [MEDIUM] SENDER-REPLYTO-MISMATCH

Evidence: From: "Partner Corp Accounts" <accounts@partner-corp.com>

Evidence: Reply-To: <partnercorp.payments@gmail.com>

Evidence: Reply-To uses a free webmail provider: gmail.com

Why it matters: Replies would go to someone other than the apparent sender, a common pattern in business-email-compromise and phishing.

Limitations: Newsletters, ticketing systems and mailing lists legitimately set a different Reply-To.

3. SPF softfail for the envelope sender [LOW] AUTH-SPF-FAIL

Evidence: spf=softfail smtp.mailfrom domain=cheap-smtp.biz

Why it matters: The server that delivered the message is not authorised to send for the envelope-sender domain, which is consistent with spoofing.

Limitations: SPF checks the Return-Path domain, not the visible From. Forwarding breaks SPF for legitimate mail.

4. Envelope sender (Return-Path) belongs to a different organisation [LOW] SENDER-RETURNPATH-MISMATCH

Evidence: From domain: partner-corp.com

Evidence: Return-Path: <bounce@cheap-smtp.biz>

Why it matters: SPF authenticates the Return-Path domain, so a mismatch means a pass for SPF does not vouch for the visible sender.

Limitations: Very common for legitimate bulk mail sent through e-mail service providers (bounce handling).

6. Limitations

- Headers can show that evidence supports or weakens a hypothesis; they cannot prove who wrote a message or whether an account was compromised.

- Received headers below the trust boundary are supplied by the sending side and may be forged.

- Authentication results are interpreted as recorded by the receiving server; signatures are not re-verified by this tool.

- Organisational domains use a built-in suffix list, not the full Public Suffix List; look-alike detection is heuristic and limited to protected domains.

- Message bodies, links and attachments are not analysed.

- Auto-trusted authserv-id 'mx1.uni-example.edu' (topmost Authentication-Results, matching the receiving server's domain).

7. Recommended next steps

- Do not act on requests in the message (payments, credentials, attachments) until the sender is verified out-of-band.

- Check the From domain's current SPF/DMARC records and compare with the receiving server's logs for this Message-ID.

- Confirm the Reply-To address with the apparent sender using a known contact channel.

- Correlate the origin IP and Message-ID with mail-server and gateway logs.

- Preserve this report together with the original file; verify the SHA-256 hash before any further processing.

Appendix A - Header fields as parsed (unfolded, in original order)

Control characters are shown as U+FFFD and very long values are truncated. The unmodified original is preserved separately under the SHA-256 above.

```
Received: from mx1.uni-example.edu (mx1.uni-example.edu [10.20.0.11]) by mailbox01.uni-example.edu with LMTP id
    8F2A1C; Mon, 14 Sep 2026 09:30:12 +0000
Authentication-Results: mx1.uni-example.edu; spf=softfail smtp.mailfrom=cheap-smtp.biz; dkim=none; dmarc=fail (p=NONE)
    header.from=partner-corp.com
Received: from mail.cheap-smtp.biz (mail.cheap-smtp.biz [91.215.85.12]) by mx1.uni-example.edu with ESMTPS id 51333156
    for <student@uni-example.edu>; Mon, 14 Sep 2026 09:30:00 +0000
Return-Path: <bounce@cheap-smtp.biz>
From: "Partner Corp Accounts" <accounts@partner-corp.com>
To: <student@uni-example.edu>
Reply-To: <partnercorp.payments@gmail.com>
Subject: Updated bank details for invoice 4471
Date: Mon, 14 Sep 2026 09:29:00 +0000
Message-ID: <379185413825.964297@partner-corp.com>
MIME-Version: 1.0
Content-Type: text/plain; charset=utf-8
```